

Cyber Crisis Management Using The Nist Cybersecurity Framework 2.0

Janvi Sethi
Computer Science
Chitkara University, Rajpura
Chandigarh, India
janvisethi44@gmail.com

Kanwardeep Singh Marzara
Computer Science
Chitkara University, Rajpura
Patiala, India
kanwarmarzara@gmail.com

Yashasvi
Computer Science
Chitkara University, Rajpura
Nirmand, India
yashasvi139sh@gmail.com

Abstract— In a world that is increasingly going digital at a rapid pace, organizations across all sizes and scopes are confronted with an unfamiliar environment of cyber threats—both advanced state-sponsored attacks and disruptive ransomware attacks on critical infrastructure. The current research paper will provide a detailed analysis of Cyber Crisis Management (CCM) in the National Institute of Standards and Technology (NIST) Cybersecurity Framework (CSF) (currently in its second major edition) (CSF 2.0) [1]. The paper examines the ways CCM strategies can be developed, implemented, and constantly enhanced by aligning the organizational processes with the six essential functions of NIST CSF—Govern, Identify, Protect, Detect, Respond, and Recover. Based on the examples of case studies, industry statistics [2][4], and the development of threat information, this paper supports the thesis that the structured crisis management systems are not just the tools of regulatory compliance but the significant operational capabilities of resilient organizations. With a thorough discussion of each of the NIST functions, the paper presents practical recommendations to security practitioners, CISOs, risk managers, and executive leadership. Other issues covered in the research include the integration of governance, supply chain risk, insiders, and the interaction of AI-based threats with the conventional cyber defense paradigm [8]. The conclusion outlines a visionary roadmap that organizations seeking to pursue the goal of having a mature and proactive cyber crisis posture can use.

Key words— Cyber Crisis Management, NIST CSF 2.0, Cybersecurity Framework, Incident Response, Organizational Resilience, Risk Management, Threat Intelligence, Business Continuity.

I. INTRODUCTION

The digital era has completely changed the way organizations conduct, communicate, and provide value. This change has however also widened the attack surface used by malicious actors. Cyber crises are no longer unique incidents confined to technological organizations; they are systemic risks that have the potential to damage healthcare systems, financial markets, government services, and industrial operations. The

examples of the Colonial Pipeline ransomware attack in 2021, the SolarWinds supply chain breach in 2020, and the exploitation of the MOVE it vulnerability in 2023 demonstrate that no industry is immune to cybercrime and that lack of appropriate preparation can result in drastic outcomes [13].

Cyber Crisis Management (CCM) refers to an organization's structured capability to prepare for, detect, respond to, and recover from major cybersecurity incidents while minimizing both operational disruption and reputational damage. In contrast to conventional incident response where the main emphasis is on the technical containment, CCM functions in several organizational areas encompassing governance, legal compliance, communications, and business continuity [7]. Published in 2014 and revised in 2024, the National Institute of Standards and Technology Cybersecurity Framework (NIST CSF) has emerged as one of the most popular cybersecurity frameworks in the world [1]. The framework offers a lifecycle-based and result-oriented strategy that organizations can use to deal with cybersecurity risk, from governance to recovery.

A. Research Objectives

The objectives of this study are: (1) to compare the correlation between the principles of Cyber Crisis Management and the functions of NIST CSF 2.0 [1]; (2) to develop best practices associated with the implementation of all NIST functions within a crisis management program; (3) to examine real cases of cybersecurity incidents to understand their implications [4][13]; (4) to consider the emerging threat vectors that influence the methods of cyber crisis management [5][8]; and (5) to provide a viable roadmap to implement NIST cyber crisis management.

B. Scope and Methodology

This paper examines cybersecurity in enterprise firms, critical infrastructures, and regulated sectors. The methodology combines research on publications by NIST [1][8], cybersecurity standards including ISO/IEC 27035 [19] and SANS PICERL, case studies of incident investigations, and research reports including the IBM Cost of a Data Breach Report 2024 [2] and the Verizon Data Breach Investigations Report 2024.

II. LITERATURE REVIEW

The intersection of cyber crisis management, organizational resilience, and standards-based frameworks has attracted growing scholarly and practitioner attention over the past decade. This section synthesizes key contributions from prior research across the domains of cybersecurity frameworks, incident response, crisis governance, threat intelligence, and emerging technology risks.

A. Evolution of Cybersecurity Frameworks

The NIST Cybersecurity Framework (CSF), first introduced in 2014, emerged as a response to Executive Order 13636 directing federal agencies to improve critical infrastructure cybersecurity. Cichonski et al. [7] laid foundational groundwork through NIST SP 800-61, establishing a structured computer security incident handling guide that continues to underpin modern incident response practices. The progression from CSF 1.0 to CSF 2.0 [1] reflects a maturation of cybersecurity thinking—most notably the elevation of governance as a discrete, equal-standing function alongside Identify, Protect, Detect, Respond, and Recover. This shift aligns with broader academic observations by Ciekankowski et al. [10] that governance deficits, not merely technical failures, are the root cause of most major cyber incidents.

Parallel frameworks such as ISO/IEC 27035 offer complementary guidance. Poitiray and Salman [19] empirically evaluated ISO 27035 deployment in enterprise environments and demonstrated measurable reductions in incident escalation time when formal information security incident management procedures are adopted. The comparative analysis of NIST CSF and ISO 27035 points to complementarity rather than competition: NIST provides a high-level strategic framework while ISO 27035 offers granular procedural guidance suited to operational incident response teams.

B. Cyber Crisis Management: Conceptual Foundations

Crisis management theory has been meaningfully extended into the cybersecurity domain. Lim [20] examined the paradigm shift from reactive security postures to resilience-based architectures, arguing that cyber threats in the modern era demand continuous adaptation rather than static defensive perimeters. This resilience imperative is echoed in NIST CSF 2.0's [1] emphasis on continuously improving capabilities across all six functions.

Manoharan [13] conducted a comprehensive analysis of the cyber threat landscape, documenting the convergence of state-sponsored actors, criminal enterprises, and hacktivists into a complex adversarial ecosystem. The study highlighted that organizations treating cybersecurity as an IT-only discipline rather than an enterprise risk management challenge demonstrate consistently poor crisis outcomes.

C. Ransomware and Critical Infrastructure Threats

Ransomware has emerged as the dominant crisis-category threat of the 2020s. Kim et al. [5] analyzed cryptocurrency-driven ransomware syndicates operating on the darknet, identifying the economic structures that sustain Ransomware-as-a-Service (RaaS) ecosystems and enable low-skilled actors to deploy high-quality attack tools.

IBM Security [2] has through its annual Cost of a Data Breach reports provided empirically grounded benchmarks for breach financial impact. Key findings—including the \$4.88 million average breach cost in 2024 and the 10% year-over-year increase—substantiate the economic rationale for CCM investment. The Mandiant M-Trends 2024 report [4] supplements this by documenting dwell times and attacker behavior patterns, which directly inform detection and response capability requirements.

The Change Healthcare ransomware attack in 2024 and the MOVEit vulnerability exploitation in 2023 illustrate the real-world consequences of inadequate CCM. Staves [18] examined operational technology preparedness from a risk-based safety perspective, noting that IT/OT convergence creates detection blind spots that traditional SIEM architectures cannot address.

D. Supply Chain Security and Third-Party Risk

The SolarWinds breach of 2020 catalyzed significant research into supply chain cybersecurity risk. Rossi [15] proposed enhanced cyber asset visibility as the foundation of effective attack surface management, arguing that organizations systematically undercount their digital footprint—a claim supported by JupiterOne data showing organizations have on average 56% more assets than their IT teams are aware of.

ENISA's reporting on the 700% growth in supply chain attacks between 2019 and 2023 has prompted regulatory responses including enhanced C-SCRM requirements in NIST CSF 2.0 [1] and the EU's NIS2 Directive. Perlroth [17] provided important historical and geopolitical context for supply chain vulnerabilities, noting that the same offensive capabilities developed by nation-states eventually proliferate to criminal actors.

E. Identity, Access Management, and Human Risk

The Verizon Data Breach Investigations Report (2024) documented that 77% of breaches involved compromised credentials, underscoring the centrality of Identity and Access Management (IAM) to cyber crisis prevention. PricewaterhouseCoopers [11] in its Global Digital Trust Insights survey found significant gaps in CISO organizational influence—only one in four organizations involves the CISO in executive leadership discussions—highlighting a governance deficit that CSF 2.0's GOVERN function directly addresses.

Lochstampfor [3] reviewed network and cyber security tools and associated costs, finding that organizations with mature IAM programs, including privileged access management (PAM) and phishing-resistant MFA, demonstrate substantially lower breach rates and reduced incident severity.

F. AI, Quantum Computing, and Emerging Threat Vectors

NIST's AI Risk Management Framework (AI RMF 1.0, 2023) [8] provides foundational guidance for managing risks associated with AI systems—guidance that CCM programs must incorporate as AI becomes embedded in both offensive tools and defensive architectures.

Alagic et al. [9] reported on the fourth round of NIST's post-quantum cryptography standardization process, documenting progress toward quantum-safe algorithms. The "harvest now, decrypt later" threat identified in their work creates an immediate CCM consideration: organizations holding sensitive data with long-horizon confidentiality requirements must initiate cryptographic migration planning now.

Babu and Moharir [6] demonstrated the utility of XGBoost machine learning in Common Vulnerabilities and Exposures (CVE) exploitability classification, representing an important step toward AI-assisted vulnerability prioritization. Lee et al. [14] proposed enhanced mapping between Risk Management Frameworks and MITRE ATT&CK using Sentence-BERT, improving the precision of threat intelligence integration into organizational risk registers.

G. Regulatory Landscape and Legal Integration

Hassan and Khadaroo [12] provided a critical analysis of the gap between organizational rhetoric and operational reality—a lens applicable to cybersecurity compliance where organizations' disclosed security postures frequently diverge from actual practices. This gap has motivated increasingly prescriptive disclosure requirements, including the SEC's four-business-day material incident disclosure rule and GDPR's 72-hour breach notification obligation.

H. Synthesis and Research Gap

The reviewed literature collectively establishes that effective cyber crisis management requires the integration of technical controls, organizational governance, human risk management, and adaptive threat intelligence [1][7][19][20]. While prior frameworks—including NIST CSF 1.0, ISO/IEC 27035 [19], and SANS PICERL—addressed elements of this challenge, none provided a comprehensive, continuously improving, governance-first framework until the release of NIST CSF 2.0 [1]. This paper addresses the gap by providing a systematic mapping of NIST CSF 2.0's six functions to operational CCM capabilities.

III. CYBER THREAT LANDSCAPE

It is impossible to appreciate Cyber Crisis Management without first developing an appreciation of the dynamic and sophisticated environment of threat that organizations face. The contemporary threat ecosystem is characterized by four dominant trends that elevate cyber incidents to crisis level.

A. Expanding Sophistication and Scope of Attacks

Threat actors are no longer informal groups of hackers but organized criminal enterprises, hacktivists, and nation-states attaining strategic objectives through cyber operations.

Advanced Persistent Threats (APTs) initiate missions in target networks months before achieving their goals. With Ransomware-as-a-Service (RaaS) ecosystems [5], more destructive capabilities have become democratized, enabling lower-skilled actors to deploy high-quality attack tools against critical targets. The average international cost of a data breach as indicated by the IBM Cost of a Data Breach Report 2024 [2] was \$4.88 million—10% more expensive than the previous year and the highest figure ever reported.

B. Critical Infrastructure Attacks

Government agencies and security researchers have reported a sustained and increasing campaign by state actors against key infrastructure areas including energy grids, water treatment plants, healthcare systems, financial networks, and transportation systems [13]. CISA has developed numerous advisories reporting on pre-positioning of nation-state actors in critical infrastructure, enabling future disruptive attacks. This geopolitical element introduces cyber crisis not only into organizational risk management but into the domain of national security.

C. Supply Chain Vulnerabilities

The SolarWinds breach demonstrated the exponential possibility of supply chain breaches, showing that a breach of a single vendor can cascade to thousands of downstream firms, government agencies, defense contractors, and Fortune 500 companies [17]. The European Union Agency for Cybersecurity (ENISA) documented a 700% growth in supply chain attacks between 2019 and 2023, making perimeter-based security models extremely challenging [15].

D. The Ransomware Crisis

In the 2020s, ransomware has become the cyber crisis vector of the decade [5]. Contemporary ransomware attackers integrate encryption and extortion mechanisms, concurrently exfiltrating data and encrypting systems, exposing organizations not only to operational disruption but also regulatory fines due to disclosure of sensitive data. This has specifically affected healthcare; the Change Healthcare ransomware attack in 2024 caused weeks of disrupted prescription handling throughout the United States, directly affecting patient care [13]. Such attacks demonstrate that cyber crises can cross the digital border to have a physical effect.

TABLE I: Cyber Threat Impact Overview

(Source: IBM Cost of a Data Breach 2024 [2]; Mandiant M-Trends 2024 [4])

Threat Category	Avg. Financial Impact	Avg. Dwell Time	Trend	Source
Ransomware	\$5.68M	49 days	↑ Rising	[2][4]
Phishing/Social Engineering	\$4.76M	24 days	↑ Rising	[2][4]
Supply Chain Attack	\$4.46M	197 days	↑ Rising	[2][4]
Insider Threat	\$4.90M	85 days	→ Stable	[2][4]
Zero-Day Exploits	\$4.55M	132 days	↑ Rising	[2][4]

IV. OVERVIEW OF NIST CYBERSECURITY FRAMEWORK 2.0

In 2024, the National Institute of Standards and Technology released the Cybersecurity Framework (CSF) 2.0 [1]—the most significant update to the framework since its initial release in 2014. CSF 2.0 is grounded in a decade of adoption experiences, expanding threat intelligence, and increasing regulatory requirements. It introduces three major enhancements not available in prior versions.

A. Introduction of the GOVERN Function

The most substantive architectural change of CSF 2.0 [1] is the elevation of governance to a separate core activity. This new GOVERN functionality recognizes that cybersecurity risk management must be integrated into organizational strategy, culture, and accountability systems, rather than being an IT department function operating in a vacuum. GOVERN includes cybersecurity policy, roles and responsibilities, risk management strategy, and oversight mechanisms. This reflects the growing recognition that cyber crises are organizational failures as much as they are technical failures [10].

B. Expanded Scope Beyond Critical Infrastructure

Though the original conception of CSF 1.0 focused on critical infrastructure operators, CSF 2.0 [1] clearly identifies its applicability to any organization regardless of size, industry, or current cybersecurity maturity. This democratization is streamlined by a tiered implementation plan—CSF Tiers 1–4—enabling organizations to assess their current cybersecurity position and identify viable improvement vectors aligned with their risk level and resource capabilities.

C. Supply Chain Risk and Third-Party Management

The recommendations on Cybersecurity Supply Chain Risk Management (C-SCRM) in CSF 2.0 [1] are radically expanded after the experiences of SolarWinds [17], Kaseya, and MOVEit. Organizations are now explicitly advised to

assess, monitor, and contractually enforce cybersecurity requirements across their technology supply chains [15], recognizing that an organization's effective attack surface extends far beyond organization-managed systems.

TABLE II: NIST CSF 2.0 Core Functions Mapped to Cyber Crisis Management
(Source: NIST CSF 2.0 [1])

Function	Core Objective	CCM Role	Key Outcomes
GOVERN	Organizational Oversight	Establishes crisis management authority, policy, and accountability	Policy, roles, risk strategy
IDENTIFY	Asset & Risk Awareness	Defines the scope of what must be protected and prioritizes risks	Asset inventory, risk register
PROTECT	Preventive Controls	Reduces probability and impact of crises via safeguards	Access control, training, hardening
DETECT	Threat Visibility	Enables early warning to contain crises before escalation	Monitoring, alerting, anomaly detection
RESPOND	Crisis Execution	Orchestrates coordinated response across technical and business teams	Incident plans, communications, containment
RECOVER	Resilience Restoration	Restores operations and integrates lessons to prevent recurrence	Recovery plans, post-incident review

V. GOVERN – ESTABLISHING THE BASIS OF CYBER CRISIS MANAGEMENT

Governance is the foundational structure that defines the transformation of technical capabilities into effective crisis management. The NIST GOVERN function [1] establishes that cybersecurity risk management is an organization-level strategic priority, accountable to leadership and underpinned by well-documented policies and processes.

A. Organizational Context and Risk Strategy

A proper governance of cyber crisis starts with a proper understanding of organizational context: the business goals, the regulatory requirements, the expectations of stakeholders, and the risk appetite that should inform all security investment and decision-making. NIST CSF 2.0 [1] mandates that organizations have a written cybersecurity risk management plan—a living document containing acceptable risk levels, conditions under which risk rises to a crisis level, and when a security incident will be considered a declared cyber crisis demanding executive involvement.

Organizations should set a Crisis Management Threshold Policy that explicitly defines when an incident warrants a crisis-level response. This threshold typically includes: duration and extent of operational disruption, sensitivity and volume of data impacted, regulatory notification triggers, risk of public disclosure, and reputational exposure [11]. The absence of a pre-approved threshold definition frequently leads organizations to waste precious response time debating threshold definitions instead of taking action.

B. Roles, Responsibilities, and Crisis Governance Structures

Cyber crises require synergistic cross-functional coordination beyond the IT organization. Best CCM governance has well-defined roles across three organizational layers [1][11]. At the strategic level, the Cyber Crisis Leadership Team (CCLT)—represented by executive leadership, typically the CEO, CISO, CFO, General Counsel, and Chief Communications Officer—makes strategic decisions, communicates with stakeholders, and meets regulatory requirements. At the operational level, the Cyber Incident Response Team (CIRT) performs technical containment, investigation, and remediation. At the tactical level, business unit liaisons guarantee continuity of vital operations and real-time communication of business impact.

A recurrent governance failure in large-scale breaches is the lack of CISO involvement in executive decisions. A PwC study [11] revealed that only one in four organizations involves the CISO in executive leadership discussions. NIST CSF 2.0 [1] directly addresses this gap by mandating documentation, communication, and enforcement of cybersecurity roles and responsibilities at the highest organizational levels.

C. Cybersecurity Supply Chain Risk Management Governance

GOVERN in CSF 2.0 [1] places strong demands on C-SCRM governance—recognizing that third-party vendors, cloud providers, and software vendors are both critical dependencies and potential attack vectors. Organizations are required to maintain vendor risk registers, conduct regular

security evaluations of key suppliers, and include contractual security requirements such as breach notification requirements, right-to-audit provisions, and incident response coordination clauses [15]. The MOVEit breach proved that a single popular file transfer tool could cause simultaneous crises across hundreds of organizations, making supply chain governance a strategic necessity [17].

VI. IDENTIFY – UNDERSTANDING WHAT NEEDS TO BE PROTECTED

You cannot protect what you do not know you have. The IDENTIFY function [1] determines the body of knowledge that forms the foundation of all other NIST functions: a full picture of organizational assets, data flows, dependencies, vulnerabilities, and threat exposures. Within the CCM paradigm, IDENTIFY determines the scope of a potential crisis and implements the prioritization of protective investments.

A. Asset Discovery and Management

The IDENTIFY function begins with total asset management—the maintenance of a correct and up-to-date register of all hardware, software, data, and individuals supporting organizational missions [1]. Modern enterprise environments feature dynamically scaled cloud workloads, shadow IT applications, operational technology (OT) systems with decades-long lifespans, and mobile endpoints traversing organizational boundaries. NIST recommends that asset inventories be automated, updated continuously, and integrated with vulnerability management and risk assessment processes [7].

A 2023 study by JupiterOne [15] found that organizations possessed on average 56% more assets than their IT teams knew about—an inventory gap that creates blind spots exploitable by threat actors. Best CCM practice requires that asset inventory extend beyond conventional IT assets to include cloud resources, API connections, third-party integrations, and data stores.

B. Business Impact Analysis and Risk Assessment

Risk assessment in the CCM context serves two purposes: to identify the most probable and impactful risk scenarios for prioritizing protective investments, and to establish a business impact baseline in the non-crisis state for rapid post-crisis recovery reference. NIST [1][7] recommends a methodical risk evaluation procedure identifying threats, vulnerabilities, likelihood, and potential business effects—creating a prioritized risk register to guide security investment and crisis planning.

Business Impact Analysis (BIA) complements risk assessment by identifying Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs) for all critical systems and processes. The outputs of BIA directly inform disaster response playbooks: which systems must be restored first, which business processes can execute in degraded mode, and what the business cost of extended outages would be [1]. Organizations that have completed BIA prior to a crisis are able to make recovery choices within minutes; those that lack

BIA data face critical delays during high-stress response scenarios.

C. Threat Intelligence Integration

Effective CCM requires the use of structured threat intelligence within the IDENTIFY function—not just understanding assets and vulnerabilities, but knowing what threat actors are targeting the organization's sector, their tactics, techniques and procedures (TTPs), and what indicators of compromise (IoCs) exist [14]. Threat intelligence sources include commercial feeds (Recorded Future, CrowdStrike Intelligence), government sharing programs (CISA, FBI Cyber Division, FS-ISAC, H-ISAC), and open-source repositories (MITRE ATT&CK, AlienVault OTX). Operationalized threat intelligence reduces mean detection time and enables proactive hardening against known adversary TTPs [14].

VII. PROTECT – INSTALLING SAFEGUARDS TO PREVENT AND LIMIT CRISES

The PROTECT function addresses security controls and mitigation measures that reduce the risk of threat actors successfully exploiting vulnerabilities, and reduce the impact when exploitation occurs [1]. In CCM terms, the savings realized through PROTECT determine the number of potential crises that never occur and the degree to which existing crises are contained.

A. Identity and Access Management

The majority of successful cyberattacks involve compromised credentials or excessive access privileges. The Verizon 2024 Data Breach Investigations Report documented that 77% of breaches were related to compromised credentials. Implementing PROTECT effectively requires a mature Identity and Access Management (IAM) program based on Zero Trust principles [3]: all users, devices, and applications must be authenticated and authorized on a case-by-case basis with reference to contextual risk, regardless of network perimeter position. Multi-Factor Authentication (MFA) is among the most cost-effective protective controls available. CISA findings show that MFA prevents over 99% of account compromise attacks [3]. Nevertheless, its adoption remains incomplete: the 2024 Microsoft Digital Defense Report claimed that MFA was not deployed on over half of Microsoft Entra ID accounts among enterprise customers. Privileged Access Management (PAM) systems further reduce crisis risk through administrative credential vaulting, just-in-time access, and comprehensive audit trails of privileged activity [3].

B. Data Protection and Backup Architecture

Data protection controls serve two CCM functions: preventing unauthorized access and exfiltration (crisis prevention), and enabling rapid data recovery following a destructive attack (crisis recovery). Organizations should apply data-at-rest and in-transit encryption, data loss prevention (DLP) systems to identify irregular exfiltration,

and data rights management on sensitive documents [1]. Backup architecture should follow the 3-2-1-1 guideline: three copies of data, two media types, one offsite, and one offline (air-gapped)—with regular restoration tests confirming backup integrity.

The ransomware era has exposed the consequences of backup architecture weaknesses. Attackers frequently find and delete available backups before rendering systems encrypted—confirmed in 93% of ransomware cases reported by Sophos in 2024 [5]. Immutable and air-gapped backup is not an optional enhancement to crisis preparedness but an operational necessity.

C. Security Awareness and Human Risk Reduction

The human factor remains the most frequently exploited attack vector. Social engineering, phishing, and insider threats are human-related risks that technical controls alone cannot eliminate [7]. Best-practice security awareness programs go beyond annual compliance training to form an organizational culture that is security-conscious—incorporating realistic phishing simulations, role-based training, executive briefings, and positive incentive programs that aid employees in reporting suspicious activity without fear of negative repercussions. NIST workforce awareness guidance [1] notes that security culture is among the PROTECT investments with the broadest organizational-level impact.

VIII. DETECT- CONTINUOUS MONITORING AND ANOMALY DETECTION

The ability to detect a cyber incident as early as possible is one of the most powerful predictors of its ultimate outcomes. The IBM 2024 Cost of a Data Breach Report [2] indicated that breaches with a detection time of less than 200 days averaged \$3.93 million in cost, compared to significantly higher costs for breaches detected after 200 days. The DETECT capability builds the monitoring, alerting, and analytics capabilities that close this critical window.

A. Security Information and Event Management (SIEM)

Security Information and Event Management (SIEM) systems collect log data from across the IT environment—including servers, endpoints, network devices, cloud services, applications, and security tools—and then centralize, correlate, and analyze it to detect patterns that may signal malicious activity. [1]. User and Entity Behavior Analytics (UEBA) complements modern SIEM solutions, enabling detection of insidious anomalies undetectable by signature-based detection: suspicious data access patterns, abnormal authentication trails, indicators of lateral movement, and command-and-control communications. Within the CCM context, SIEM provides not only detection but also a forensic audit trail required for incident investigation [7].

B. Security Operations Centers and 24/7 Monitoring

Continuous monitoring is essential for effective detection, as attackers do not limit their activities to business hours; in fact, studies on attacker dwell time show that many intrusions start during evenings, weekends, and holidays when monitoring resources are typically reduced. [4]. Organizations can deploy detection functions using an internal Security Operations Center (SOC), a co-managed SOC with a Managed Security Service Provider (MSSP) partner, or an outsourced Managed Detection and Response (MDR) service. Regardless of the model, detection programs must be supported by clear detection use cases, alert tuning to minimize false positives, documented escalation procedures, and periodic tabletop exercises validating detection behavior against realistic attack scenarios [1].

C. Threat Hunting

Threat hunting is the proactive process in which skilled analysts manually explore the environment to uncover signs of threat actor activity that automated detection tools might miss.[4]. The philosophy of threat hunting rests on an assumption of breach—the recognition that an attacker may already be present—and employs hypothesis-driven investigation approaches grounded in threat intelligence to detect covert attacks. Threat hunting activities are integrated into the incident response process of highly mature organizations, with confirmed threat actor activity triggering formal incident investigation procedures [14].

D. Internet of Things and Operational Technology Detection

IT-OT integration—encompassing industrial control systems, SCADA systems, building management systems, and IoT devices—creates identification loopholes for organizations that apply SIEM and network monitoring only to conventional IT environments [18]. OT and IoT devices may lack built-in logging capabilities, use proprietary protocols incompatible with standard SIEM tools, and reside on subnets intentionally isolated from IT systems. NIST CSF 2.0 [1] explicitly discusses OT/ICS settings, and CCM programs in organizations with significant OT footprints must extend detection architectures to those environments using specialized tools such as Claroty, Dragos, or Nozomi Networks.

IX. RESPOND – CYBER CRISIS RESPONSE IMPLEMENTATION

When a cyber crisis strikes, the difference between organizations that emerge with manageable impact and those that are severely damaged often lies in how they prepared before the crisis and how they executed their response [1][7]. The RESPOND function encompasses all activities required to contain, investigate, and communicate during a cyber crisis while maintaining coordinated stakeholder engagement.

A. Incident Response Plan Architecture

The operational center of RESPOND is an Incident Response Plan (IRP). NIST SP 800-61r2 [7][16] defines the incident

response lifecycle as four stages: Preparation; Detection and Analysis; Containment, Eradication, and Recovery; and Post-Incident Activity. The IRP must exceed technical processes and integrate crisis communication protocols, legal and regulatory standards, executive authority frameworks, and business continuity provisions to fulfill the full CCM mission.

Effective IRPs are framework-based, with a master plan containing dedicated playbooks for the most probable crisis incident types: ransomware, data breach, DDoS attack, insider threat, supply chain compromise, and cloud service provider outage [1][5]. Each playbook should include: indicators of detection, immediate containment procedures, evidence preservation policies, template communications, escalation limits, and recovery policies.

B. Communications Management During a Cyber Crisis

Communications management is one of the most challenging and important characteristics of CCM. Organizations must manage internal communications (informing employees and preventing panic-driven actions), regulatory notifications (compliance with GDPR, HIPAA, SEC regulations, and state breach notification legislation), and customer, partner, and media communications [12]. Mismanagement of crisis communications—including delays in disclosure, misinformation, or tone-deaf responses—can generate reputational costs that exceed the direct financial cost of the event itself.

Prepared communications templates, designated spokespersons, and pre-drafted media holding statements accelerate the communications response during a crisis. Organizations are encouraged to establish a crisis communications war room independent of the technical response team, allowing technical responders to focus on containment while communications professionals manage stakeholder engagement [11]. Legal counsel must be integrated into the response from the initial stages to mitigate regulatory and litigation risks in all communications.

C. Containment and Eradication Strategies

Containment decisions during a cyber crisis require balancing the immediate necessity to stop the spread of damage against the duty to preserve evidence and ensure sufficient operational continuity to meet business needs [7][18]. Swift containment actions—network segmentation, account suspension, system isolation—must be performed decisively but without losing awareness of operational dependencies that could cause collateral damage. Once containment is achieved, evidence of threat actor presence, malware, persistence mechanisms, backdoors, and compromised credentials are systematically eradicated based on forensic analysis rather than intuition.

X. RECOVER – RESTORING CAPABILITIES AND INTEGRATING LESSONS

The RECOVER function addresses activities that restore normal functioning after a cyber crisis and integrate experience to create organizational resilience [1]. Recovery

is not a purely technical restoration exercise; it must be coordinated with stakeholder expectations, regulatory demands, insurance processes, and organizational learning.

A. Recovery Planning and Prioritization

Recovery activities should be guided by Business Continuity Plans (BCPs) and Disaster Recovery Plans (DRPs) that specify BIA-based RTOs and RPOs for all critical systems [1]. NIST CSF 2.0 emphasizes that recovery planning must be practiced through regular exercises—tabletop exercises, functional exercises, and full-scale exercises—to test recovery procedures before an actual crisis requires them [7]. Organizations that have not tested recovery plans frequently discover during an active crisis that backups are invalid, recovery procedures are unfamiliar, or recovery time estimates were unrealistically optimistic.

Recovery prioritization should be tiered: life-safety systems first (particularly in medical and industrial environments), then mission-critical business systems, then important operational systems, and finally administrative and non-critical systems [1]. Pre-determining such prioritization with senior management approval enables rapid recovery decision-making and eliminates the negotiation delays that have historically extended recovery times in actual crisis scenarios.

B. Post-Incident Review and Continuous Improvement

One of the most valuable but often overlooked components of the NIST framework [1] is the post-incident review, which should be conducted two to four weeks after crisis resolution while the incident is still fresh. The After-Action Review (AAR) involves a structured review of the incident record, analysis of detection and response effectiveness, identification of plan or tooling gaps, and development of a prioritized remediation roadmap. The AAR should examine both technical failures and organizational issues: communication failures, decision-making delays, resource inadequacies, and training gaps.

NIST [1] specifically treats recovery as a continuous improvement procedure—every cyber crisis, whether minor or major, is a learning experience that should enhance the organization's overall cybersecurity posture. High-maturity organizations incorporate AAR findings into their risk registers, security roadmaps, and training programs, forming a feedback loop that progressively minimizes the likelihood and impact of future crises.

C. Stakeholder Restoration and Reputation Management

Recovery extends beyond technical systems to restoring stakeholder trust [12]. Organizations should actively share recovery progress with customers, partners, regulators, and employees—demonstrating their capability to manage crises and their commitment to preventing recurrence. Organizations that successfully restore stakeholder trust after cyber crises are characterized by transparent communication, clear accountability, and demonstrated remedial measures rather than defensive or evasive responses. Parallel recovery activities requiring specific resources and legal coordination

include cyber insurance claims management, regulatory cooperation, and litigation management.

XI. IMPLEMENTING CCM THROUGHOUT THE ENTERPRISE

Effective Cyber Crisis Management cannot function as a standalone IT activity; it must be integrated into the organizational structure, linking cybersecurity processes with enterprise risk management, business continuity, legal and compliance processes, and executive governance [1][11].

A. CCM Maturity Assessment and Roadmap

Organizations are advised to evaluate their CCM maturity using the NIST CSF Tier model [1]—ranging from Tier 1 (Partial: ad-hoc, reactive) to Tier 4 (Adaptive: proactive, continuously improving). Maturity assessment provides an organized perspective on gaps across all six NIST functions and enables the creation of a prioritized improvement roadmap aligned with the organization's risk profile and resource constraints. The roadmap must include specific measurable milestones with ownership assignments, and must be incorporated into the overall security strategy and budget planning cycles.

TABLE III: NIST CSF Tier Maturity Model Applied to CCM Capabilities

(Source: NIST CSF 2.0 [1])

NIST Tier	Governance	Detection Capability	Response Capability	Recovery Maturity
Tier 1 Partial	Ad-hoc policies	Manual, reactive	No formal plan	No tested DR plan
Tier 2 Informed	Documented policies	SIEM deployed	IRP documented	BCP exists, untested
Tier 3 Repeatable	Approved & enforced	24/7 SOC coverage	Exercised IRP	BCP tested annually
Tier 4 Adaptive	Board-level oversight	AI-augmented detection	Automated playbooks	Continuous DR testing

B. Integration of Regulatory and Legal Issues

CCM programs should be coordinated with the full range of relevant regulatory requirements [12]. For U.S. organizations, this includes SEC cybersecurity disclosure rules (material incident disclosure within four business days), HIPAA breach notification rules (60 days for covered entities), FTC Safeguards Rule requirements for financial institutions, and 50 different state-level breach notification statutes. Internationally, GDPR requires breaches affecting EU citizens to be reported to data protection authorities within 72 hours.

Legal counsel should be designed into CCM programs not merely as a crisis response resource but to ensure that incident response procedures, communications, and evidence preservation practices are legally sound [12]. Attorney-client

privilege considerations, evidence preservation requirements, and the choice to cooperate with regulators must be pre-determined and embedded in crisis management playbooks.

C. Cyber Insurance Alignment

Cyber insurance is an important CCM financial tool, offering coverage over incident response expenses, business interruption losses, regulatory fines, third-party liability, and extortion payments [3]. Underwriting requirements have evolved significantly with rising losses; insurers now require specific security controls (MFA, EDR, backup isolation, incident response planning) as conditions of coverage. CCM programs should be constructed with cyber insurance requirements in mind, ensuring that documented capabilities can be substantiated during underwriting and claims processes.

XII. FUTURE PROJECTIONS AND EMERGING THREATS FOR CCM

The world of cyber threats does not stand still, and CCM programs calibrated for the current threat set will be ill-equipped to address tomorrow's challenges. This section reviews the top emerging threat vectors and their implications for NIST-compliant CCM capability development.

A. AI as Both Threat and Defense

Artificial intelligence is transforming both sides of the cybersecurity equation with significant implications for CCM [8]. On the threat side, AI enables attackers to create large-scale phishing content (including voice and video deepfakes), conduct advanced social engineering, scale vulnerability discovery and malware development, and adapt attack patterns in real time based on defensive actions. The technical barrier to advanced attacks has dropped significantly, and AI technology now available to criminal groups surpasses the capabilities of state-sponsored attackers from a decade ago. On the defensive side, AI enhances detection through behavioral analysis, accelerates threat hunting, automates routine response tasks (isolating infected machines, blocking malicious IP addresses, revoking stolen credentials), and generates human-readable incident summaries that enable rapid executive decision-making during crises [6][8]. The NIST AI Risk Management Framework (AI RMF) [8], published in 2023, provides guidance for addressing AI-specific risks that CCM programs at AI-adopting organizations must incorporate.

B. Quantum Computing and Cryptographic Risk

Although realistic quantum computers capable of breaking current encryption standards remain years away, the "harvest now, decrypt later" threat exists today: attackers are storing encrypted data with the intention of decrypting it once quantum computers become available [9]. Alagic et al. [9] documented progress toward quantum-safe algorithms in NIST's post-quantum cryptography standardization process. This creates a long-horizon CCM consideration: organizations holding sensitive data requiring decades of confidentiality must initiate quantum-safe cryptography transitions immediately.

C. Critical Infrastructure and OT/ICS Threats

State-sponsored actors have made significant investments in capabilities to disrupt, degrade, and destroy critical infrastructure—energy grids, water networks, communications networks, and financial market infrastructure [13][18]. The convergence of IT and OT environments means that cyberattacks previously limited to information systems now threaten physical processes and, in extreme scenarios, human life. CCM programs for critical infrastructure organizations must bridge the IT/OT gap, creating cohesive governance, shared threat intelligence, and joint incident response capacity capable of addressing both information and operational crises simultaneously.

D. The Resilience Imperative

The evolving threat landscape has motivated a fundamental shift in cybersecurity philosophy—from prevention-based security (the belief that a sufficiently secure perimeter can keep intruders out) to resilience-based security (the recognition that breaches will eventually occur, and that detection, response, and recovery capabilities can be optimized) [20]. NIST CSF 2.0 [1] reflects this philosophy: while PROTECT remains critical, the framework clearly elevates GOVERN, DETECT, RESPOND, and RECOVER as equally crucial investments. The ultimate goal of Cyber Crisis Management is resilience—not the elimination of crises, which is not achievable, but the organizational ability to absorb, adapt, and recover from crises with minimum damage.

XIII. CONCLUSION

Cyber Crisis Management has ceased to be a specialized technical field; it is now a fundamental business skill at the intersection of technology, governance, business continuity, legal compliance, and stakeholder communications. The rate, complexity, and severity of cyber crises continue to grow, and organizations that view cybersecurity as a technical matter dealt with exclusively by the IT department will remain unprepared when a crisis occurs [13][20].

NIST Cybersecurity Framework 2.0 [1] offers the most comprehensive, widely adopted, and practically feasible framework for constructing a mature Cyber Crisis Management capability. Its six core functions—GOVERN, IDENTIFY, PROTECT, DETECT, RESPOND, and RECOVER—are not sequential steps but interrelated, continuously improving capabilities that compose an adaptive organizational defense. The introduction of GOVERN in CSF 2.0 is of particular significance: it recognizes that cybersecurity resilience is an organizational challenge requiring leadership commitment, strategic alignment, and cultural transformation, rather than a set of technical controls.

The returns for organizations that invest in NIST-aligned CCM capabilities are quantifiable: reduced dwell times, reduced breach costs, faster recovery, enhanced regulatory compliance, and improved stakeholder trust. IBM's 2024 research [2] has consistently demonstrated that organizations with incident response teams and tested IRPs save an average of \$1.49 million per breach compared to those that do not.

The business case for CCM investment is strong and supported by empirical evidence.

The convergence of AI-sophisticated threats [8], quantum computing implications [9], an expanding OT attack surface [18], and intensifying geopolitical cyber warfare will continue to challenge even the most mature CCM programs. Organizations must treat Cyber Crisis Management as a continuous improvement discipline—periodically assessing their posture, testing their capabilities, incorporating new threat data, and adapting their models to a threat environment that will never stop changing [1][20].

The organizations best positioned to survive the cyber crises of the next decade will not necessarily be those with the largest security budgets, but those that can most effectively convert their investments—regardless of size—into well-coordinated, rehearsed, and continuously enhanced crisis management capabilities grounded in the structured framework that the NIST Cybersecurity Framework provides [1].

REFERENCES

- [1] National Institute of Standards and Technology (US). (2024). NIST Cybersecurity Framework 2.0: Quick-Start Guide for Creating and Using Organizational Profiles. US Department of Commerce, National Institute of Standards and Technology.
- [2] IBM Security. (2024). Cost of a Data Breach Report 2024. IBM Corporation.
- [3] Lochstampfor Jr, C. (2025). Network & Cyber Security: Tools, Costs, and Efficiency.
- [4] Mandiant. (2024). M-Trends 2024: Special Report. Google LLC. Retrieved from <https://www.mandiant.com/resources/reports/m-trends-2024>
- [5] Kim, K., Lee, S., Ramachandran, S., & Alzahrani, I. (2025). Cryptocurrency-driven ransomware syndicates operating on the darknet: A focused examination of the Arab world. *Egyptian Informatics Journal*, 30, 100665.
- [6] Babu, M., & Moharir, M. (2024, November). Leveraging XGBoost Machine Learning Algorithm for Common Vulnerabilities and Exposures (CVE) Exploitability Classification. In 2024 8th International Conference on Computational System and Information Technology for Sustainable Solutions (CSITSS) (pp. 1–6). IEEE.
- [7] Cichonski, P., Millar, T., Grance, T., & Scarfone, K. (2012). Computer Security Incident Handling Guide. NIST Special Publication 800-61, 1–147.
- [8] National Institute of Standards and Technology. (2023). Artificial Intelligence Risk Management Framework (AI RMF 1.0). <https://nvlpubs.nist.gov/nistpubs/ai/nist.ai.100-1.pdf>
- [9] Alagic, G., Bros, M., Ciadoux, P., Cooper, D., Dang, Q., Dang, T., & Waller, N. (2025). Status Report on the Fourth Round of the NIST Post-Quantum Cryptography Standardization Process. US Department of Commerce, National Institute of Standards and Technology.
- [10] Ciekanowski, Z., Gruchelski, M., Nowicka, J., Zurawski, S., & Pauliuchuk, Y. (2023). Cyberspace as a Source of New Threats to the Security of the European Union.
- [11] PricewaterhouseCoopers. (2024). Global Digital Trust Insights 2024: A C-Suite United on Cyber-Ready Futures. PwC.
- [12] Hassan, O. A., & Khadaroo, I. (2026). A Critical Analysis of Microsoft's Rhetoric and Reality of Sustainability Engagement. *Business Strategy and the Environment*.
- [13] Manoharan, A. (2024). Understanding the threat landscape: A comprehensive analysis of cyber-security risks in 2024. *International Research Journal of Modernization in Engineering Technology and Science*, 6(3), 5706–5713.
- [14] Lee, H., Yoon, S., Lee, Y., & Kang, J. (2026). Enhancing RMF and ATT&CK Mapping Accuracy through Sentence-BERT and Mitigation Parameters Integration.
- [15] Rossi, M. C. (2023). Enhancing Cyber Assets Visibility for Effective Attack Surface Management.
- [16] Cichonski, P., Millar, T., Grance, T., & Scarfone, K. (2012). Computer Security Incident Handling Guide. NIST Special Publication 800-61, 1–147.
- [17] Perlroth, N. (2021). *This Is How They Tell Me the World Ends: The Cyberweapons Arms Race*. Bloomsbury Publishing USA.
- [18] Staves, A. J. (2023). Operational Technology Preparedness: A Risk-Based Safety Approach to Scoping Security Tests for Cyber Incident Response and Recovery. Lancaster University (United Kingdom).
- [19] Poetiray, I. F. Z., & Salman, M. (2023). Information security incident management using ISO 27035 standard. *Gema Wiralodra*, 14(3), 168–178.
- [20] Lim, I. C. Cybersecurity in an Age of Complexity: Outlook Since 2022 and What to Do Next